أسئلة مقالية في التحكم في الوصول (Access Control)

١. اشرح مفهوم التحكم في الوصول (Access Control) في أمن الحاسوب.

ناقش أهدافه، ومكوناته الأطراف Subjects ، الموارد Objects ، وحقوق الوصول Access Rights، وأهميته في حماية نظم المعلومات.

التحكم في الوصول هو أسلوب أمني يستخدم لتنظيم من يمكنه الوصول إلى الموارد داخل نظام الحاسوب وكيفية هذا الوصول.

يهدف إلى ضمان أن المستخدمين المصرح لهم فقط (Subjects) يمكنهم الوصول إلى الموارد (Objects) وفقا لصلاحيات محددة.

المكونات:

- Subjects المستخدمون/ العمليات
- Objects الموارد مثل الملفات وقواعد البيانات
- Access Rights الصلاحيات مثل القراءة والكتابة والتنفيذ

الأهداف:

- حماية السرية (Confidentiality)
- الحفاظ على السلامة (Integrity)
- ضمان التوافر (Availability)

الأهمية:

يساعد التحكم في الوصول في منع الوصول غير المصرح به، وتقليل المخاطر الأمنية وحماية البيانات الحساسة

٢. قارن بين نماذج التحكم في الوصول التالية:

- التحكم الاختياري (DAC)
- التحكم الإلزامي (MAC)
- التحكم المعتمد على الدور (RBAC)

مع تقديم أمثلة لكل نموذج، وشرح المميزات والعيوب لكل منها.

النموذج	الوصف	المميزات	العيوب
DAC	المالك يتحكم في الصلاحيات	مرن	أقل أمانا
MAC	جهة مركزية تتحكم	أمان عالي	جامد وغير مرن
RBAC	يعتمد على الأدوار	قابل للتوسع	تعقيد إدارة الأدوار

أمثلة:

- DAC مشاركة الملفات في Windows
- MAC الأنظمة العسكرية
- RBAC أنظمة الشركات

٣. ناقش نموذج مصفوفة التحكم في الوصول . (Access Control Matrix) اشرح كيفية تطبيقه باستخدام

قوائم التحكم في الوصول (ACLS) - قوائم القدرات (Capability Lists)

مع توضيح المميزات والقيود لكل طريقة.

هي جدول يوضح الصلاحيات التي يمتلكها كل مستخدم على كل مورد

طرق التطبيق:

- قوائم التحكم في الوصول: (ACIS) مرتبطة بالموارد
- قوائم القدرات: (Capability Lists) مرتبطة بالمستخدمين

المميزات:

- تمثيل واضح

٤. التحكم في الوصول المعتمد على الدور (RBAC)

يعتمد RBAC على منح الصلاحيات بناءً على الأدوار بدلاً من المستخدمين الأفراد.

خطوات العمل:

١. تعريف الأدوار (مثل مدير، موظف)

٢. تخصيص الصلاحيات لكل دور

٣. إسناد المستخدمين للأدوار

المميزات:

- تبسيط الإدارة
- تعزيز الأمان
- مناسب للأنظمة الكبيرة

٥. حلل المشكلات الأمنية المرتبطة بنموذج التحكم الاختياري . (DAC) لماذا يعتبر هذا النموذج أقل أمانا مقارنة بالنماذج الأخرى؟

- يمكن للمستخدمين نقل الصلاحيات للآخرين
- عرضة لهجمات Trojan Horse

٦. اشرح كيفية عمل آليات التحكم في الوصول في أنظمة Linux UNIX/يجب أن يتضمن الشرح:

صلاحيات الملفات - الملكية (Ownership) - المجموعات (Groups) -قوائم التحكم في الوصول (ACLS)

يعتمد UNIX على نظام الصلاحيات.

أنواع الصلاحيات:

- قراءة (R)
- كتابة (W)
- تنفيذ (X)

الفئات:

- المالك
- المجموعة
- الآخرون

ACLS:

تسمح بإعطاء صلاحيات إضافية المستخدمين محددين

٧. ناقش مفهوم مبدأ أقل صلاحية (Principle of Least Privilege)

كيف يرتبط هذا المبدأ بأنظمة التحكم في الوصول ؟ وكيف يساهم في تحسين أمن النظام ؟

ينص هذا المبدأ على إعطاء المستخدم أقل قدر ممكن من الصلاحيات اللازمة لأداء عمله.

الفوائد:

- تعزيز أمان النظام وتقليل الاختراقات
- الحد من المخاطر الداخلية (Insider Threats)
- تحسين التحكم والمراقبة على المستخدمين

٨. شرح كيفية تطبيق التحكم في الوصول في أنظمة التشغيل الحديثة وقواعد البيانات. مع تقديم أمثلة واقعية.

تشمل الأنظمة الحديثة:

- RBAC في المؤسسات
- المصادقة متعددة العوامل (MFA)
- التحكم في قواعد البيانات

مثال: تستخدم أنظمة الحوسبة السحابية مثل AWS سياسات IAM.

- يعزز الالتزام بالسياسات
- لكن سوء تصميم الأدوار قد يقلل من كفاءته.

٩. ناقش التحديات التي تواجه تصميم وإدارة أنظمة التحكم في الوصول في المؤسسات الكبيرة. واقترح حلولا مناسبة لهذه التحديات.

أنظمة التحكم في الوصول في المؤسسات الكبيرة بتواجه تحديات زي التعقيد، التوسع، والتغير المستمر، لكن يمكن التغلب عليها من خلال:

- استخدام نماذج تنظيمية قوية
- الاعتماد على الأتمتة
- تطبيق سياسات أمنية صارمة
- استخدام أدوات حديثة لإدارة الهوية

١٠. قيم فعالية نموذج RBAC في بيئات المؤسسات.

كيف يستاهم في تحقيق الأمان، وقابلية التوسع، وسهولة الإدارة؟

1. تحقيق الأمان(Security)

- يعتمد على **مبدأ أقل صلاحية** :**(Least Privilege)**
- تحديد الصلاحيات حسب الدور
- يسهل **مراجعة الصلاحيات**
- يقلل مخاطر الاختراق الداخلي.(Insider Threats)

2. قابلية التوسع(Scalability)

- إضافة دور جديد بسهوله
- مناسب للأنظمة الكبيرة زي البنوك والجامعات

3. سهولة الإدارة(Manageability)

- إدارة مركزية للأدوار
- تعديل صلاحيات دور واحد ينعكس على كل المستخدمين المرتبطين به.
- يقلل التعقيد في الأنظمة الكبيرة.

11. اشرح الفرق بين المصادقة (Authentication)، التخويل (Authorization) وكيف يعملان معا داخل أنظمة التحكم في الوصول؟

العنصر	Authentication	Authorization
المعنى	التحقق من الهوية	تحديد الصلاحيات
مثال	تسجيل الدخول	الوصول للملفات

العلاقة:

يتم التحقق أولاً ثم تحديد الصلاحيات

١٢- التحكم المعتمد على الخصائص (ABAC)

يعتمد ABAC على خصائص مثل:

- دور المستخدم
- الموقع
- الوقت

المقارنة:

- RBAC يعتمد على أدوار ثابتة ١
- ABAC يعتمد على قرارات ديناميكية

الميزة:

مرن ومناسب للأنظمة الحديثة

اسئلة امن المعلومات والانظمة

١. اشرح مفهوم توثيق المستخدم (User Authentication) في أمن الحاسوب.

ناقش الهدف منه وأهميته في حماية نظم المعلومات.

مفهوم توثيق المستخدم.

توثيق المستخدم هو عملية التحقق من هوية المستخدم قبل منحه حق الوصول إلى النظام يعد خطوة اساسية في أمن المعلومات لضمان أن الشخص الذي يحاول الدخول هو بالفعل من يدعيه.

الأهداف:

- منع الوصول غير المصرح به
- حماية البيانات العامة
- دعم سياسات الأمان

الأهمية:

يساعد في تأمين الأنظمة وتقليل احتمالية الاختراقات والهجمات الإلكترونية.

٢. اشرح العوامل الثلاثة الرئيسية للتوثيق

شيء تعرفه (Something you know) - شيء تملكه (Something you have)

شيء تمثله (Something you are)، مع إعطاء أمثلة لكل عامل، وتقييم المميزات والعيوب.

عوامل التوثيق الثلاثة

تعتمد انظمة التوثيق على ثلاثة عوامل رئيسية:

١. شيء تعرفه مثل كلمة المرور

٢. شيء تملكه مثل البطاقة الذكية أو الهاتف

٣. شيء تمثله مثل بصمة الإصبع أو الوجه

التقييم:

- العامل الأول سهل الاستخدام لكنه ضعيف الأمان
- العامل الثاني أكثر أمانا لكنه قد يفقد
- العامل الثالث قوي لكنه مكلف ويثير مخاوف الخصوصية

٣. ناقش أنظمة التوثيق المعتمدة على كلمات المرور.

ما هي نقاط الضعف الشائعة فيها؟ وكيف يمكن الحد منها؟

التوثيق بكلمات المرور

هو أكثر أنواع التوثيق استخدامًا.

نقاط الضعف:

- كلمات مرور ضعيفة
- إعادة استخدام كلمات المرور
- سهولة التخمين

الحلول:

- استخدام كلمات مرور قوية
- تغييرها بشكل دوري
- تطبيق سياسات امان صارمة

٤. شرح مفهوم التوثيق متعدد العوامل (Multi-Factor Authentication - MFA)

كيف يساهم في تحسين الأمان مقارنة بالتوثيق أحادي العامل؟

التوثيق متعدد العوامل (MFA)

يعتمد على استخدام أكثر من عامل توثيق.

الميزة:

حتى إذا تم اختراق عامل واحد، تبقى العوامل الأخرى تحمى النظام

مثال: كلمة مرور + رمز يرسل إلى الهاتف

٥. ناقش طرق التوثيق البيومتري مثل: بصمة الإصبع - التعرف على الوجه - مسح قزحية العين وقيم المميزات، والقيود، والمخاطر الأمنية.

التوثيق البيومتري:

يعتمد على الخصائص الحيوية للمستخدم

الميزات:

- صعب التزوير
- سهل الاستخدام

العيوب:

- تكلفة عالية
- مشاكل الخصوصية
- إمكانية الخطأ

.6اشرح كيفية عمل بروتوكولات التوثيق في أمن الشبكات.
مع ذكر أمثلة مثل أسلوب التحدي والاستجابة(Challenge-Response) .

بروتوكولات التوثيق: هي آليات للتحقق من الهوية عبر الشبكات.

مثال: Challenge Response حيث يرسل النظام تحديا ويجب على المستخدم الرد بشكل صحيح.

٧. ناقش الهجمات الشائعة على أنظمة التوثيق، مثل:

هجمات القوة الغاشمة (Brute Force) - هجمات القاموس (Dictionary Attacks)
التصيد الاحتيالي (Phishing) - هجمات إعادة الإرسال (Replay Attacks)
وكيف يمكن الوقاية منها؟

الهجمات على أنظمة التوثيق

أنواع الهجمات:

- القوة الغاشمة
- هجمات القاموس
- التصيد الاحتيالي
- إعادة الإرسال

الحماية:

- استخدام MFA
- التشفير
- التوعية الأمنية

٨. اشرح مفهوم تسجيل الدخول الموحد . (Single Sign-On – SSO)
ناقش مزاياه والمخاطر الأمنية المحتملة.

يسمح للمستخدم بتسجيل الدخول مرة واحدة للوصول إلى عدة انظمة.

الميزات:

- سهولة الاستخدام
- تقليل عدد كلمات المرور

المخاطر:

- نقطة فشل واحدة
- إذا تم اختراق الحساب، تتأثر جميع الخدمات

٩. ناقش دور التوثيق في الأنظمة الحديثة مثل الحوسبة السحابية والخدمات الإلكترونية. مع تقديم أمثلة واقعية.

يستخدم في:

- الحوسبة السحابية
- التطبيقات البنكية
- الخدمات الإلكترونية

مثال: استخدام Google أو Microsoft تسجيل الدخول الموحد.

10 اشرح كيفية تخزين كلمات المرور بشكل آمن.

ناقش تقنيات

التجزئة (Hashing) - إضافة الملح (Salting) - إطالة المفاتيح (Key Stretching)

يتم تخزينها باستخدام:

- Hashing تحويل الكلمة إلى قيمة غير قابلة للعكس
- Salting: إضافة قيمة عشوائية
- Key Stretching زيادة تعقيد الحساب:.

الهدف: منع سرقة كلمات المرور.

١١. التوثيق بالرموز مقابل كلمات المرور

العنصر	كلمات المرور	الرموز
الأمان	اقل	أعلى
الاستخدام	سهل	يحتاج جهاز
المخاطر	التخمين	القد

١٢ ناقش الاتجاهات الحديثة في توثيق المستخدم، مثل:

- التوثيق بدون كلمة مرور(Passwordless authentication)
- القياسات الحيوية السلوكية (Behavioral biometrics)
- التوثيق التكيفي (Adaptive Authentication)

الاتجاهات الحديثة

امثلة:

- التوثيق بدون كلمة مرور
- القياسات الحيوية السلوكية
- التوثيق التكيفي

الفائدة:

- تحسين الأمان
- تحسين تجربة المستخدم
- تقليل الاعتماد على كلمات المرور

أسئلة مقالية – الأدوات التشفيرية

١. اشرح مفهوم الأدوات التشفيرية (Cryptographic Tools) في أمان الحاسوب.

ناقش دورها في تحقيق: السرية (Confidentiality) ، السلامة (Integrity) ، التوثيق (Authentication) وعدم الإنكار (Non-repudiation)

مفهوم الأدوات التشفيرية:

الأدوات التشفيرية (Cryptographic Tools) هي مجموعة من الخوارزميات والتقنيات المستخدمة لحماية المعلومات أثناء التخزين أو النقل عبر الشبكات، بهدف منع الوصول غير المصرح به وضمان أمن البيانات.

دورها في الأمن:

- السرية (Confidentiality)

يتم ضمانها من خلال التشفير بحيث لا يمكن قراءة البيانات إلا من قبل الأطراف المصرح لها.

- السلامة (Integrity)

يتم التأكد من أن البيانات لم يتم تعديلها أثناء النقل باستخدام دوال التجزئة Hash Function

- التوثيق (Authentication)

التأكد من هوية المستخدم أو الطرف الآخر باستخدام التوقيعات الرقمية أو الشهادات.

- عدم الإنكار (Non-repudiation)

يمنع الطرف المرسل من إنكار إرسال البيانات باستخدام التوقيع الرقمي.

٢. ناقش الفرق بين:

- التشفير بالمفتاح المتماثل (Symmetric-Key Cryptography)
- التشفير بالمفتاح العام (Public-Key Cryptography)

مع تقديم أمثلة لكل منهما، وتحليل المميزات والعيوب.ان وجدت

الفرق بين التشفير المتماثل وغير المتماثل

Symmetric key Cryptography

. يستخدم مفتاح واحد للتنفير وفك التشفير

أمثلة: AES DES.

المميزات:

- سريع في التنفيذ.
- مناسب للبيانات الكبيرة.

العيوب:

- مشكلة توزيع المفتاح.
- أقل أماناً إذا تم تسريب المفتاح

Public-key Cryptography

- يستخدم مفتاحين عام وخاص
- امثلة RSA,ECC

المميزات:

- حل مشكلة توزيع المفاتيح.
- أمان أعلى في تبادل البيانات.

العيوب:

- ابطا من التشفير المتماثل
- يحتاج الي قدرة حسابية اكبر.

٣. اشرح كيفية عمل عمليتي التشفير وفك التشفير(Encryption & Decryption) قم بتوضيح الإجابة باستخدام رسم تخطيطي. (Block Diagram)

. عملية التشفير وفك التشفير

الشرح:

- التشفير: تحويل النص الأصلي (Plaintext) إلى نص مشفر (Ciphertext)
- فك التشفير: إعادة النص المشفر إلى نصه الأصلي باستخدام مفتاح

مخطط (Block Diagram)

Plaintext + Key → Encryption Algorithm → Ciphertext

Ciphertext + Key → Decryption Algorithm → Plaintext

٤. ناقش مفهوم دوال التجزئة. (Hash Functions)اشرح خصائصها ودورها في ضمان سلامة البيانات.

دوال التجزئة(Hash Functions)

هي خوارزميات تحول البيانات إلى قيمة ثابتة الطول تسمى " Hash Value"

الخصائص:

- لا يمكن عكسها (One-way function).
- سرعة في الحساب.
- مقاومة التصادم (Collision Resistance)

الدور:

- ضمان سلامة البيانات.
- اكتشاف أي تعديل في الرسالة.
- تستخدم في التوقيعات الرقمية.

٥. التوقيعات الرقمية

هي تقنية تستخدم للتحقق من هوية المرسل وضمان عدم تغيير الرسالة.

آلية العمل:

- يتم إنشاء Hash للرسالة
- يتم تشفير الـ Hash باستخدام المفتاح الخاص.
- يتم إرسال الرسالة والتوقيع.

الأهمية:

- التوثيق (Authentication)
- عدم الإنكار (Non-repudiation)
- سلامة البيانات (Integrity) .

6. MACs ودورها ومقارنتها بالـ Hash

Message Authentication Code (MAC):

هو رمز ينشأ باستخدام مفتاح سري لضمان سلامة وأصالة الرسالة.

الدور: التحقق من أن الرسالة لم يتم تعديلها التأكد من مصدر الرسالة.

المقارنة مع: Hash

العنصر	Hash Function	MAC
المفتاح	لا يستخدم	يستخدم مفتاح سري
الأمان	اقل	أعلى
التوثيق	لايوفر	يوفر

٧.اشرح مشكلة إدارة المفاتيح (Key Management) في التشفير. لماذا تُعتبر من أكثر التحديات تعقيدا في الأنظمة الآمنة؟

تشمل توليد، توزيع، تخزين، وتحديث المفاتيح التشفيرية.

التحدي:

- صعوبة توزيع المفاتيح بشكل امن
- خطر فقدان أو تسريب المفتاح.
- الحاجة إلى إدارة عدد كبير من المفاتيح في الأنظمة الكبيرة.

٨. ناقش أهمية توليد الأرقام العشوائية (Random Number Generation) في الأنظمة التشفيرية. ما هي خصائص المولد الجيد

. توليد الأرقام العشوائية

الأهمية:

تستخدم في توليد المفاتيح التشفيرية والتوقيعات الرقمية.

خصائص المولد الجيد:

- العشوائية (Randomness)
- عدم التنبؤ.
- الاستقلالية.
- التوزيع المتساوي للقيم.

9. PKI ودورها في الاتصالات الآمنة

البنية التحتية للمفتاح العام (PKI) هي نظام لإدارة المفاتيح والشهادات الرقمية.

المكونات:

- الشهادات الرقمية.
- هيئة إصدار الشهادات (CA)
- هيئة التسجيل (RA)

الدور:

- تأمين تبادل المفاتيح.
- التحقق من الهوية الرقمية.
- دعم التوقيعات الرقمية.

١٠. الفرق بين الشهادات الرقمية والتوقيعات الرقمية

:Digital certificate

. وثيقة رقمية تربط الهوية بالمفتاح العام.

:Digital signature

. تقنية للتحقق من سلامة الرسالة وهوية المرسل.

الاستخدام معا:

- الشهادة تثبت هوية المستخدم.
- التوقيع يثبت أن الرسالة لم تتغير.

١١. ناقش الهجمات الشائعة على الأنظمة التشفيرية مثل:

- هجمات القوة الغاشمة (Brute Force)
- التحليل التشفيري (Cryptanalysis)
- هجمات الرجل في الوسط (Man-in-the-Middle)

وكيف يمكن التصدي لهذه الهجمات؟

Brute force attack:

- تجربة جميع المفاتيح الممكنة.
- الوقاية: استخدام مفاتيح طويلة.

Cryptanalysis:

- تحليل الخوارزميات الاكتشاف المفتاح.
- الوقاية خوارزميات قوية مثل AES

Man-in-the-Middle:

- اعتراض الاتصال بين طرفين.
- الوقاية SSL/TLS : والشهادات الرقمية.

١٢. ناقش الاتجاهات الحديثة في التحكم في الوصول مثل التحكم المعتمد على

Quantum -resistant Cryptography

- خوارزميات مقاومة للحوسبة الكمية.
- مهمة لمواجهة أجهزة الكم المستقبلية.

Blockchain Cryptography

- تعتمد على التشفير التأمين المعاملات.
- تستخدم في العملات الرقمية.

Lightweight Cryptography

- خوارزميات خفيفة للأجهزة الصغيرة. (IoT)
- توفر أمان مع استهلاك منخفض للطاقة.

امن قواعد البيانات

١- مفهوم التشفير والفرق بين التشفير المتماثل وغير المتماثل:

التشفير هو عملية تحويل البيانات من شكلها الأصلي (نص واضح) إلى شكل غير مفهوم (نص مشفر) لحمايتها من الوصول غير المصرح به.

- **التشفير المتماثل : (Symmetric Encryption)**

يستخدم نفس المفتاح للتشفير وفك التشفير، وهو سريع لكنه يتطلب تأمين المفتاح.

- **التشفير غير المتماثل(Asymmetric Encryption)**

يستخدم مفتاحين (عام وخاص)، أحدهما للتشفير والآخر لفك التشفير، وهو أكثر أما الكنه أبطأ.

٢. تعريف التحكم في الوصول والفرق بين RBAC و DAC

التحكم في الوصول هو آلية تحدد من يمكنه الوصول إلى الموارد وما هي العمليات التي يمكنه تنفيذها.

◇ **RBAC (Role-based access control):**

يعتمد على الأدوار الوظيفية، حيث يتم منح الصلاحيات حسب دور المستخدم.

◇ **DAC (Discretionary access control):**

يعتمد على مالك المورد، حيث يمكنه تحديد من يملك صلاحية الوصول.

٣. مفهوم التحكم في الوصول وأهميته في المؤسسات

التحكم في الوصول هو مجموعة من السياسات والإجراءات التي تحدد من يمكنه الوصول إلى الموارد داخل النظام وما هي الصلاحيات الممنوحة له.

أهميته:

- حماية البيانات الحساسة من الوصول غير المصرح به.
- تقليل مخاطر الاختراقات والهجمات الداخلية والخارجية.
- ضمان أن كل مستخدم يصل فقط إلى ما يحتاجه (مبدأ أقل امتياز).
- تعزيز الامتثال للسياسات الأمنية والقوانين.

٤. اشرح نموذج تشفير قواعد البيانات: (Database Encryption)

تشفير قواعد البيانات:

يوضح مثال تشفير قاعدة البيانات وجود أربع جهات رئيسية:

- **مالك البيانات: (Data Owner)** المؤسسة التي تنتج البيانات الحساسة
- **المستخدم: (User)** يرسل الاستعلامات إلى النظام
- **العميل: (Client)** واجهة امامية تقوم بتحويل الاستعلامات إلى استعلامات على بيانات مشفرة
- **الخادم : (Server)** يستقبل البيانات المشفرة ويخزنها ويتيحها للعملاء (وعادة يكون تابعا لمزود خارجي)

فكرة التشفير:

يتم تشفير كل عنصر في قاعدة البيانات بشكل منفصل باستخدام نفس مفتاح التشفير

يتم التخزين البيانات المشفرة في الخادم بدون وجود مفتاح التشفير

العميل فقط لديه مفتاح التشفير لفك البيانات

خطوات الاستعلام:

١. المستخدم يرسل استعلام SQL باستخدام المفتاح الأساسي

٢. يقوم العميل بتشفير المفتاح الأساسي وتعديل الاستعلام ثم إرساله إلى الخادم

٣. الخادم يعالج الاستعلام باستخدام البيانات المشفرة ويعيد النتائج

٤. العميل يقوم بفك التشفير واظهار البيانات للمستخدم

٥. خطوات تشفير قواعد البيانات (Database Encryption)

١. تحديد البيانات الحساسة:

تحديد الجداول أو الحقول التي تحتوي على معلومات مهمة مثل كلمات المرور أو البيانات المالية.

٢. اختيار نوع وخوارزمية التشفير:

اختيار التشفير المناسب (متماثل أو غير متماثل) والخوارزمية الملائمة.

٣. إدارة مفاتيح التشفير:

إنشاء مفاتيح قوية وتخزينها بشكل آمن مع تحديد سياسات لتحديثها وحمايتها.

٤. تطبيق التشفير:

تشفير البيانات إما أثناء التخزين (At Rest) أو أثناء النقل (In Transit)

٥. اختبار النظام:

التأكد من أن عملية التشفير وفك التشفير تعمل بشكل صحيح دون التأثير على أداء النظام

٦. تحديد صلاحيات الوصول:

السماح فقط للمستخدمين المصرح لهم بالوصول إلى البيانات المشفرة أو مفاتيح التشفير

٧. المراقبة والصيانة:

متابعة النظام بشكل دوري، وتحديث الخوارزميات والمفاتيح عند الحاجة لضمان استمرار الأمان.

٦. مفهوم أمن البيانات وعناصر نموذج CIA Triad

أمن البيانات هو حماية البيانات من الوصول غير المصرح به أو التعديل أو الفقدان

. عناصر CIA Triad :

- السرية: (Confidentiality) حماية البيانات من الاطلاع غير المصرح به.
- السلامة: (Integrity) ضمان عدم تعديل البيانات بشكل غير صحيح
- التوافر: (Availability) ضمان توفر البيانات عند الحاجة.

. وسيلة حماية: استخدام التشفير

٧. مفهوم أمن البيانات وعناصر CIA Triad ووسائل الحماية:

أمن البيانات هو حماية البيانات من التهديدات مثل الاختراق أو الفقدان أو التعديل غير المصرح به.

. عناصر نموذج CIA Triad

- السرية: (Confidentiality) منع الوصول غير المصرح به إلى البيانات.
- السلامة: (Integrity) الحفاظ على دقة وصحة البيانات.
- التوافر: (Availability) ضمان توفر البيانات عند الحاجة.

. وسائل حماية البيانات:

- التشفير: لحماية البيانات أثناء التخزين والنقل.
- النسخ الاحتياطي: لاستعادة البيانات في حال الفقدان أو الكوارث.
- الجدران النارية: لمنع الوصول غير المصرح به إلى الشبكات والأنظمة.

٨. عرف مفهوم المصادقة (Authentication) ، ثم اذكر بإيجاز أنواعها المختلفة، ووضح أهمية استخدام المصادقة متعددة العوامل (MFA) او

٢. ما المقصود بالمصادقة؟ استعرض أنواع المصادقة باختصار، وبين أهمية تطبيق المصادقة متعددة العوامل (MFA) في تعزيز أمن المعلومات.

المصادقة (Authentication):

هي عملية التحقق من هوية المستخدم أو النظام للتأكد من أنه الشخص المصرح له بالوصول إلى الموارد أو البيانات.

أنواع المصادقة بإيجاز:

١. المصادقة المعتمدة على المعرفة : (Something you know) مثل كلمة المرور أو الرقم السري.

٢. المصادقة المعتمدة على الملكية : (Something you have) مثل البطاقة الذكية أو رمز يرسل إلى الهاتف

٣. المصادقة المعتمدة على الخصائص الحيوية: (Something you are) مثل بصمة الإصبع أو التعرف على الوجه

أهمية المصادقة متعددة العوامل : (MFA)

تزيد من مستوى الأمان لأنها تعتمد على أكثر من عامل للتحقق من الهوية، مما يجعل من الصعب على المهاجمين اختراق الحساب حتى في حال معرفة كلمة المرور، وبالتال تقال من مخاطر الوصول غير المصرح به وتحمي البيانات الحساسة.

٩. اهم التهديدات التى تواجه أمن البيانات في المؤسسات، مع وسيلة حماية لكل تهديد:

١. **الوصول غير المصرح به (Unauthorized Access)**

يحدث عندما يتمكن شخص غير مخول من الدخول إلى النظام أو قاعدة البيانات

وسيلة الحماية : استخدام أنظمة المصادقة القوية مثل كلمات المرور المعقدة والمصادقة متعددة العوامل (MA)

٢. **هجمات حقن (SQL SQL Injection)**

يقوم المهاجم بإدخال أوامر SQL خبيثة للوصول إلى البيانات أو تعديلها

وسيلة الحماية: استخدام الاستعلامات المعدة مسبقا (Prepared Statements) والتحقق من صحة المدخلات

٣. **البرمجيات الخبيلة : (Maharare)**

تشمل الفيروسات وبرامج التجسس التي قد تسرق أو تدمر البيانات

وسيلة الحماية : تثبيت برامج مكافحة الفيروسات وتحديثها باستمرار

٤. **تسريب البيانات (Data Leakage)**

حدوث تسرب للبيانات الحساسة داخل أو خارج المؤسسة

وسيلة الحماية : تشفير البيانات (Encryption) أثناء التخزين والنقل.

٥. **هجمات الحرمان من الخدمة (Denial of Service-DoS)**

تؤدى إلى تعطيل النظام ومنع المستخدمين من الوصول إلى البيانات

وسيلة الحماية : استخدام جدران الحماية (Firewalls) وأنظمة كشف ومنع التسال (IDS/IPS)

٦. **الأخطاء البشرية : (Human Errors)**

مثل حذف البيانات أو مشاركتها بشكل غير مقصود

وسيلة الحماية: تدريب الموظفين وتطبيق سياسات أمنية واضحة.

٧. **فقدان البيانات (Data Loss)**

بسبب اعطال الأجهزة أو الكوارث

وسيلة الحماية : إجراء نسخ احتياطى دورى (Backup) و خطط استعادة البيانات (Recovery)

١٠. وضح الفرق بين المصادقة (Authentication) والتفويض (Authorization) مع مثال لكل منهما.؟

- **المصادقة (Authentication)**

هي عملية التحقق من هوية المستخدم للتأكد من أنه الشخص الذي يدعيه، ويتم ذلك باستخدام بيانات مثل اسم المستخدم وكلمة المرور أو بصمة الإصبع.

مثال: عند إدخال اسم المستخدم وكلمة المرور التسجيل الدخول إلى نظام الجامعة.

- **التفويض (Authorization)**

هو عملية تحديد الصلاحيات الممنوحة للمستخدم بعد التحقق من هويته، أي ما الذي يسمح له بالوصول إليه أو تنفيذه داخل النظام

مثال: بعد تسجيل الدخول يسمح الطالب فقط بعرض درجاته، بينما يسمح للأستاذ بادخال وتعديل الدرجات

- **الفرق باختصار:**

المصادقة تتحقق من **من أنت؟**

أما التفويض فيحدد **ماذا يمكنك ان تفعل ؟**

أسئلة صح وخطا:

١. يتم استخدام تشفير البيانات الحماية البيانات من الوصول غير المصرح به (صح)

٢. المصادقة (Authentication) تضمن أن المستخدم لديه صلاحية الوصول إلى البيانات. (خطأ)

٣. حقن (SQL Injection) SQL هو نوع من الهجمات التي تستهدف قواعد البيانات. (صح)

٤. النسخ الاحتياطي والاسترجاع غير مهمين في أمن قواعد البيانات. (خطا)

٥. التحكم في الوصول (Access Control) يحدد من يمكنه عرض أو تعديل البيانات. (صح)

٦. الجدران النارية (Firewalls) لا تساعد في حماية قواعد البيانات من الهجمات الخارجية. (خطا)

٧. تكامل البيانات (Data Integrity) يضمن بقاء البيانات دقيقة ومنسقة مع مرور الوقت. (صح)

٨. استخدام كلمات مرور قوية يقلل من خطر الوصول غير المصرح به إلى قاعدة البيانات. (صح)

٩. تدقيق قواعد البيانات (Database Auditing) يستخدم لمراقبة وتتبع أنشطة قاعدة البيانات. (صح)

١٠. يجب أن يمتلك جميع المستخدمين نفس صلاحيات الوصول داخل نظام قاعدة البيانات. (خطا)

أولا: ادوات التشفير (Cryptographic Tools)

١. ما الهدف الأساسي من التشفير؟

A) زيادة سرعة الشبكة B) حماية البيانات من الوصول غير المصرح به

C) حذف البيانات D) نسخ البيانات

٢. أي من التالي يعتبر خوارزمية تشفير متماثل؟

أ) RSA ب) AESC ج) SHA-256 د) ECC

٣. التشفير غير المتماثل يعتمد على:

A مفتاح واحد B) مفتاحين عام وخاص C) كلمة مرور فقط D) رقم تعريف المستخدم

٤. وظيفة دالة التجزئة (Hash Function) هي:

A) تشفير البيانات B) ضغط البيانات C) تحويل البيانات إلى قيمة ثابتة الطول D) حذف البيانات

٥. أي من التالي يعتبر خوارزمية Hash ؟

أ) AES ب) RSA ج) SHA-256 د) DES

ثانيا: المصادقة (User Authentication)

٦. الهدف من المصادقة هو:

A) تحديد سرعة النظام B)التحقق من هوية المستخدم C) تشفير الملفات D) إدارة الشبكة

٧. أي مما يلي يُعتبر عامل مصادقة (Authentication Factor)؟

A) ما تعرفه (كلمة المرور) B) ما لا تحتاجه C) سرعة الإنترنت D) نوع الجهاز فقط

٨. المصادقة الثنائية (FA٢) تعني:

A) استخدام كلمة مرور فقط B) استخدام عاملين للتحقق C) تسجيل الدخول مرتين D) استخدام جهازين

٩. وأي مما يلي مثال على "ما تملكه"؟

A) بصمة الإصبع B) كلمة المرور C) بطاقة ذكية D) الإجابة السرية

١٠. البصمة تصنف ضمن:

A) شيء تعرفه B) شيء تملكه C) شيء أنت عليه D) شيء تنساه

١١. أي هجوم يستهدف كلمات المرور ؟

a) Dos B) Brute Force c) Phishing d) Spoofing

ثالثا: التحكم في الوصول (Access Control)

١٢. الهدف من التحكم في الوصول هو :

(A) تسريع النظام (B منع الوصول غير المصرح به للموارد

C)حذف المستخدمين D) تقليل الذاكرة

١٣. أي نموذج تحكم في الوصول يعتمد على أدوار المستخدمين؟

أ) DAS ب) MAC ج) RBAC د) Hashing

١٤. في نموذج DAC ، يتم تحديد الصلاحيات بواسطة:

A) النظام B) المالك C) الحكومة D) الشبكة

١٥ نموذج MAC يعتمد على:

A) المستخدم B) النظام والسياسات الأمنية C) كلمة المرور D) التطبيقات

١٦. قائمة التحكم في الوصول ACL تعني:

A) قائمة التطبيقات B) قائمة المستخدمين (C) قائمة الصلاحيات D)قائمة الأجهزة

١٧. أي مما يلي يعتبر عنصرا في نظام التحكم في الوصول؟

A) المستخدم B) الكائن (Object) (C) الصلاحية D) جميع ما سبق

١٨. يعني "Capability Ticket"

A) كلمة مرور (B) رمز يمنح صلاحيات الوصول (C) بريد إلكتروني D)عنوان IP

١٩. في UNIX التقليدي يتم التحكم في الوصول عبر:

A) الجدار الناري فقط B) صلاحيات القراءة / الكتابة / التنفيذ (C) الذكاء الاصطناعي D) الشبكة فقط

٢٠. أي مما يلي يعتبر مثالاً على "Access Right" ؟

A) Read B) Encrypt C) Log in D) Hash

رابعا : مقدمة في امن المعلومات وادارة المخاطر

١٠ أسئلة اختيار من متعدد (MCQ) في مقدمة إدارة المخاطر وأمن المعلومات

١. ما هو أمن المعلومات؟

A. حماية الأجهزة فقط B. حماية المعلومات من الوصول أو الاستخدام أو التعديل غير المصرح به

C.زيادة سرعة الإنترنت D.تصميم البرمجيات

٢. ما هو تعريف الخطر (Risk) في أمن المعلومات؟

A. خسارة مؤكدة الحدوث B. احتمال استغلال تهديد لنقطة ضعف

C. نوع من الجدران النارية D . سياسة أمنية

٣. ما هو الهدف الأساسي لأمن المعلومات؟

A. تقليل تكلفة النظام فقط B. تحقيق السرية والسلامة والإتاحة (CIA)

C. زيادة حجم الملفات D. تحسين البرمجة

٤. ماذا تعني السرية (Confidentiality) ؟

A. البيانات متاحة دائماً B. البيانات لا يتم تعديلها

C. منع الوصول غير المصرح به إلى المعلومات D. نسخ احتياطي للبيانات

٥. ماذا تعني السلامة (Integrity) ؟

A. تشفير البيانات فقط B. ضمان أن البيانات صحيحة وغير معدلة بشكل غير مصرح به

C . حذف البيانات باستمرار D . جعل البيانات متاحة للجميع

٦. ماذا تعني الاتاحة (Availability)؟

A. إخفاء البيانات B. الوصول إلى البيانات عند الحاجة

C. تشفير البيانات D. ضغط البيانات

٧. ما هي نقطة الضعف (Vulnerability) ؟

A) أداة حماية B) ضعف في النظام يمكن استغلاله C) سياسة أمنية D. جدار حماية

٨. ما هو التهديد (Threat) ؟

A. سبب محتمل لإحداث ضرر للنظام B. برنامج حماية C. نظام نسخ احتياطي D. سياسة كلمات مرور

٩. إدارة المخاطر تهدف بشكل أساسي إلى:

A تصميم المواقع B تحديد وتقليل المخاطر الأمنية C زيادة سعة التخزين D. تحسين سرعة الأجهزة

١٠. أي مما يلي يُعد مثالاً على وسيلة تحكم أمنية (Security Control) ؟

A) جدار الحماية (Firewall) B) جدول بيانات (Spreadsheet)

C . سجل التصفح. D . صندوق البريد الإلكتروني

١١. أي مما يلي يمثل أفضل تعريف الإدارة المخاطر في أمن المعلومات؟

A) القضاء الكامل على جميع التهديدات C) زيادة سرعة الشبكة

B. تحديد وتقييم وتخفيف المخاطر إلى مستوى مقبول D. تطوير البرمجيات فقط

١٢. العلاقة الصحيحة بين عناصر المخاطر هي:

A. Risk = Asset + Firewall B. Risk = Threat x Vulnerability x Impact

C. Risk = Password + Encryption D. Risk = Data x Speed

٣. أي مما يلي يعتبر مثالاً على تهديد داخلي (Insider Threat) ؟

A. هجوم من قراصنة خارجيين B. موظف يستخدم صلاحياته بشكل غير صحيح

C. انقطاع الإنترنت D فشل جهاز التوجيه

٤. ما الفرق الأساسي بين التهديد (Threat) ونقطة الضعف (Vulnerability) ؟

A. التهديد هو الضعف والنقطة هي الهجوم C. لا يوجد فرق بينهما

B. التهديد هو مصدر خطر، بينما الضعف هو قابلية الاستغلال D. كلاهما يعني جدار الحماية

٥. أي مما يلي يُعد إجراء وقائيا (Preventive Control) ؟

A. كشف الهجوم بعد حدوثه B. النسخ الاحتياطي للبيانات

C جدار الحماية (Firewall) D. تحليل السجلات

٦. أي نوع من الضوابط الأمنية يهدف إلى اكتشاف الحوادث الأمنية؟

A. Preventive Control B. Detective Control

C. Corrective Control D. Physical Control

٧. أي من التالي يمثل مبدأ تقليل الامتيازات (Least Privilege)

A منح جميع المستخدمين صلاحيات المدير C. مشاركة كلمة المرور

B. إعطاء المستخدم أقل صلاحيات لازمة لإنجاز عمله D. عدم استخدام التشفير

٨. أي من التالي يعتبر من أصول المعلومات (Information Asset)

A جهاز الكمبيوتر فقط B البيانات والأنظمة والأشخاص

C الإنترنت فقط D البرامج المجانية فقط

٩. عند تقييم المخاطر، أي عنصر يعتبر من "Impact" ؟

A. احتمال وقوع التهديد B. حجم الضرر الناتج عن الحادث

C. عدد المستخدمين D. نوع الشبكة

١٠ أي مما يلي يُعد مثالاً على ضابط تعويضي (Compensating Control)

A. استبدال كلمة المرور بنظام بدون حماية

B. استخدام المصادقة الثنائية عند ضعف نظام الحماية الأساسي

C. إزالة جميع الصلاحيات

D. إيقاف النظام بالكامل